

RAPPORT DE TESTS DE SÉCURITÉ

Reconnaissance réseau (Nmap) & tests applicatifs (OWASP ZAP) — CYNA-IT

Version	1.0	Date	28/06/2026
Rédacteur	Renaud NASSOU OROU — Responsable Sécurité	Référentiels	PTES · OWASP · MITRE ATT&CK
Périmètre	Lab CYNA-IT — Nmap, OWASP ZAP, Wazuh, Suricata	Diffusion	Interne

Le présent rapport synthétise les tests de sécurité réalisés sur l'infrastructure du projet CYNA-IT. Il couvre la phase de reconnaissance réseau menée avec **Nmap**, les tests applicatifs Web réalisés avec **OWASP ZAP** sur la forge Gitea, ainsi que la corrélation des activités avec la solution de supervision **Wazuh / Suricata**. Les tests ont été exécutés dans un cadre autorisé, sur un environnement de laboratoire maîtrisé.

1 Objet et cadre du test

L'objectif est d'évaluer l'exposition des machines du laboratoire, d'identifier les services accessibles et les défauts de configuration, et de vérifier la bonne détection des activités offensives par le SIEM. Les tests sont strictement défensifs : ils visent à documenter et corriger les faiblesses, sans exploitation ni atteinte à la disponibilité des services.

- tests autorisés et limités au périmètre du laboratoire CYNA-IT ;
- approche non destructive (reconnaissance, scan, analyse passive et active maîtrisée) ;
- validation croisée des détections dans Wazuh (Security events, MITRE ATT&CK).

2 Périmètre et environnement

Cible / hôte	Rôle	Observations
10.20.0.107	Machine surveillée	SSH exposé, autres ports filtrés (pare-feu actif)
10.10.10.6	Serveur DevOps (Gitea)	Double service SSH + interface Web Gitea « CYNA-IT DevOps »
SRV-SECU-GENEVE	Manager Wazuh (SIEM)	Collecte et corrélation des événements
Agent-ansible	Agent Linux supervisé	Source des journaux PAM / sshd analysés

Outils utilisés : Nmap (scan réseau et détection de services / OS), OWASP ZAP (analyse de sécurité applicative Web), Wazuh et Suricata (détection et corrélation).

3 Méthodologie

- **Découverte réseau** : identification des hôtes et contournement du filtrage ICMP (option -Pn) ;
- **Scan de ports et services** : énumération des ports ouverts, versions et empreinte système ;
- **Analyse applicative Web** : exploration (spider) puis analyse active de l'interface Gitea ;

- **Corrélation SIEM** : vérification des alertes générées dans Wazuh et de leur classement MITRE ATT&CK.

4 Résultats — Reconnaissance réseau (Nmap)

4.1 — Scan de l'hôte 10.20.0.107

```
nmap -Pn -sV -sC -O 10.20.0.107
```

Port	État	Service	Version
22/tcp	ouvert	ssh	OpenSSH 9.x (Ubuntu)
443/tcp	filtré	https	—
3000/tcp	filtré	(web)	—
9000/tcp	filtré	—	—
9200/tcp	filtré	—	—

L'hôte ne répond pas aux sondes ICMP (option `-Pn` nécessaire), ce qui traduit une configuration de filtrage. Seul le service SSH (port 22) est accessible ; les autres ports apparaissent filtrés, signe d'une politique de pare-feu restrictive. Le système distant est identifié comme un noyau Linux.

4.2 — Scan de l'hôte 10.10.10.6 (serveur DevOps)

```
nmap -Pn -sV -sC 10.10.10.6
```

Port	État	Service	Version / bannière
22/tcp	ouvert	ssh	OpenSSH 9.6p1 (Ubuntu)
222/tcp	ouvert	ssh	OpenSSH 10.2
3000/tcp	ouvert	http	Gitea — page « CYNA-IT DevOps »

Deux services SSH distincts sont exposés sur deux ports différents (22 et 222), augmentant la surface d'attaque et le risque de force brute. Le port 3000 expose une interface Web Gitea accessible, répondant en HTTP/1.0 et positionnant un cookie de session (`i.like.gitea`). L'absence de chiffrement TLS sur cette interface constitue le point d'attention principal de la phase suivante.

5 Résultats — Tests applicatifs Web (OWASP ZAP)

Une analyse a été menée avec OWASP ZAP sur l'interface Gitea (`http://10.10.10.6:3000`), via une phase d'exploration automatisée (spider) suivie d'une analyse active. Les alertes remontées sont synthétisées ci-dessous, par niveau de risque.

ID	Alerte ZAP	Risque	Réf. (CWE)
----	------------	--------	------------

ZAP-01	Identifiants transmis en clair (interface en HTTP)	HAUTE	CWE-319
ZAP-02	En-tête Content-Security-Policy (CSP) absent	MOYENNE	CWE-693
ZAP-03	Protection anti-clickjacking absente (X-Frame-Options)	MOYENNE	CWE-1021
ZAP-04	En-tête HSTS (Strict-Transport-Security) absent	BASSE	CWE-319
ZAP-05	Cookie de session sans attribut HttpOnly / Secure / SameSite	BASSE	CWE-1004
ZAP-06	En-tête X-Content-Type-Options absent (MIME sniffing)	BASSE	CWE-693
ZAP-07	Divulgaration d'informations de version (serveur / application)	BASSE	CWE-200
ZAP-08	Commentaires / méthodes HTTP — information	INFO	CWE-200

5.1 — Constats détaillés et risques

- **ZAP-01 — Transmission en clair** : l'authentification Gitea s'effectue sur HTTP. Les identifiants et le cookie de session circulent sans chiffrement et peuvent être interceptés sur le réseau (écoute passive). Risque majeur pour une forge hébergeant du code source.
- **ZAP-02 / ZAP-03 / ZAP-06 — En-têtes de sécurité manquants** : l'absence de CSP, d'en-tête anti-clickjacking et de X-Content-Type-Options expose l'interface aux injections de contenu, au détournement par cadre (clickjacking) et au MIME sniffing.
- **ZAP-04 — HSTS absent** : aucune politique ne force l'usage de HTTPS, laissant la porte ouverte à une rétrogradation de protocole.
- **ZAP-05 — Attributs de cookie** : le cookie de session ne porte pas les attributs HttpOnly, Secure et SameSite, augmentant le risque de vol de session (XSS, transmission en clair, CSRF).
- **ZAP-07 — Divulgaration de versions** : les bannières de version (SSH, application) facilitent la recherche de vulnérabilités connues par un attaquant.

6 Corrélation avec la détection Wazuh

Les activités menées pendant les tests ont été correctement détectées et classées par le SIEM, ce qui valide la chaîne agent → manager → tableau de bord.

Activité de test	Détection Wazuh	Technique MITRE ATT&CK
Scan de ports / services (Nmap)	Pics d'activité réseau, événements de découverte	T1046 — Network Service Discovery
Tentatives d'authentification SSH	« Authentication failure » (PAM / sshd, règle 5503, niveau 5)	T1110.001 — Password Guessing

Ces détections apparaissent dans *Security events* et dans le module MITRE ATT&CK du tableau de bord Wazuh, confirmant l'efficacité de la corrélation.

7 Synthèse des risques

ID	Constat	Sévérité
----	---------	----------

SEC-01	Identifiants Gitea transmis en clair (interface HTTP)	HAUTE
SEC-02	Double service SSH exposé (ports 22 et 222)	HAUTE
SEC-03	Interface Gitea exposée sans en-têtes de sécurité	MOYENNE
SEC-04	En-têtes HTTP de sécurité manquants (CSP, XFO, HSTS, XCTO)	MOYENNE
SEC-05	Attributs de cookie de session manquants	BASSE
SEC-06	Divulgateur de versions logicielles (SSH / application)	BASSE
SEC-07	Tentatives d'authentification SSH détectées par Wazuh	MOYENNE

8 Recommandations et plan d'action

- exposer Gitea exclusivement en **HTTPS (TLS 1.3)**, rediriger HTTP vers HTTPS et activer HSTS ;
- restreindre l'accès à l'interface Gitea au seul **VLAN DevOps** ;
- **désactiver ou filtrer le second service SSH** ; n'autoriser SSH que depuis le VLAN de gestion, par clés uniquement, avec MaxAuthTries réduit et fail2ban ;
- ajouter les **en-têtes de sécurité** manquants (CSP, X-Frame-Options, X-Content-Type-Options) ;
- durcir les **attributs de cookie** de session (HttpOnly, Secure, SameSite) ;
- **masquer les bannières de version** des services exposés ;
- maintenir la corrélation Wazuh / Suricata et le suivi des règles de détection.

9 Conclusion

Les tests confirment une politique de filtrage réseau globalement saine, mais mettent en évidence deux points sensibles : l'exposition d'un double service SSH et, surtout, l'accès à la forge Gitea en clair sans en-têtes de sécurité. La correction prioritaire porte sur le passage en HTTPS et le durcissement de l'exposition Web. Par ailleurs, la solution Wazuh a démontré sa capacité à détecter et classer les activités offensives (T1046, T1110.001), validant le dispositif de supervision du projet CYNA-IT.